

HTB ACADEMY · BẢN GHI CHÉP CUỐI MÔ-ĐUN

Thu thập thông tin — Phiên bản web (Information Gathering — Web Edition)

Bản tái cấu trúc với lý thuyết được tổng hợp trong bản gốc tiếng Bồ Đào Nha, lời giải thực hành đặt ngay sau phần tương ứng, giữ hình thức bản xuất trước và luồng đọc tự nhiên hơn. Nội dung nay được dịch sang tiếng Việt.

- **Mức độ:** Dễ · Tier 2
- **Trọng tâm:** Trình sát web chủ động, thụ động
- **Cấu trúc:** mỗi phần lý thuyết tiếp nối bằng bài thực hành tương ứng nếu có
- **Giữ nguyên:** log, đáp án cuối từ tài liệu thực hành trong cuộc trò chuyện gốc

Cách đọc: dùng bản đồ mô-đun để di chuyển nhanh, sau đó đọc từng phần theo thứ tự. Lời giải thực hành có trong cuộc trò chuyện gốc đặt ngay sau lý thuyết tương ứng để dễ ôn, đối chiếu, học.

Bản đồ mô-đun

#	Tên phần gốc	Bản dịch	Thực hành
1	Introduction	Giới thiệu	—
2	WHOIS	WHOIS	—
3	Utilising WHOIS	Sử dụng WHOIS	Có
4	DNS	DNS	—
5	Digging DNS	Điều tra DNS	Có
6	Subdomains	Tên miền con	—
7	Subdomain Bruteforcing	Dò vết cạn tên miền con	Có
8	DNS Zone Transfers	Chuyển vùng DNS	Có
9	Virtual Hosts	Máy chủ ảo	Có
10	Certificate Transparency Logs	Nhật ký minh bạch chứng chỉ	—
11	Fingerprinting	Nhận diện công nghệ	Có
12	Crawling	Thu thập theo liên kết	—
13	robots.txt	robots.txt	—
14	Well-Known URIs	URI chuẩn được biết trước	—
15	Creepy Crawlies	Công cụ thu thập web	Có
16	Search Engine Discovery	Khám phá bằng công cụ tìm kiếm	—
17	Web Archives	Kho lưu trữ web	Có
18	Automating Recon	Tự động hóa trình sát	—
19	Skills Assessment	Đánh giá kỹ năng	Có

Các phần tổng hợp

Luồng ôn tập thống nhất: tóm lược lý thuyết trước, thực hành tương ứng sau nếu đã làm trong cuộc trò chuyện gốc. Phần không có thực hành riêng được ghi gọn để giữ nhịp trình bày.

Phần 1/19 — Giới thiệu

Bản dịch của Introduction

Trình sát web là nền tảng đánh giá web nhất quán. Trước tìm lỗi, hiểu bề mặt: tài sản công khai, tên miền con, IP, công nghệ, điểm vào tiềm năng.

- Mục tiêu: nhận diện tài sản, tìm thông tin ẩn, phân tích bề mặt tấn công, thu tình báo hữu ích cho bước sau.
- Chủ động tương tác trực tiếp: quét cổng, thu banner, liệt kê dịch vụ, nhận diện OS, thu thập web.
- Thụ động dùng nguồn công khai: tìm kiếm, WHOIS, DNS, kho web, mạng xã hội, kho mã; giảm nguy cơ phát hiện.
- Chọn theo phạm vi, mức trưởng thành mục tiêu, mức dấu vết chấp nhận.

Không lưu bài thực hành riêng trong cuộc trò chuyện gốc. Giữ luồng trình bày, chỉ tổng hợp lý thuyết.

Phần 2/19 — WHOIS

WHOIS là giao thức và các cơ sở dữ liệu đăng ký tên miền. Giúp biết ai đăng ký, ngày tạo, hết hạn, liên hệ, máy chủ tên liên quan.

- Trường hữu ích: tên miền, nhà đăng ký, chủ đăng ký, liên hệ quản trị/kỹ thuật, ngày tạo/hết hạn, máy chủ tên.
- Lịch sử giúp xem đổi chủ, nhà đăng ký, hạ tầng theo thời gian.
- Dù che dữ liệu nhạy cảm, vẫn có bối cảnh độ lâu đời tên miền, quan hệ nhà cung cấp/đăng ký.

Không lưu bài thực hành riêng; chỉ tổng hợp lý thuyết, giữ luồng trình bày.

Phần 3/19 — Sử dụng WHOIS

WHOIS thực tế trong điều tra phishing, phân tích malware, tình báo đe dọa. Giá trị không chỉ trường riêng mà liên hệ ngày, chủ đăng ký, hạ tầng, mẫu lặp.

- Miền mới, chủ ẩn, máy chủ tên đáng ngờ cũng cố giả thuyết phishing.
- Với malware/C2, gọi vị trí, nhà đăng ký để dãi, hạ tầng tái sử dụng.
- Mẫu nhiều miền giúp xây hồ sơ chiến dịch, bí danh, chiến thuật tác nhân.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 4/19 — DNS

Domain Name System chuyển tên dễ nhớ sang IP, tổ chức phân giải theo cấp máy chủ gốc, TLD, máy có thẩm quyền, resolver. Trình sát web dùng DNS thấy tài sản, phụ thuộc, manh mối tổ chức trong.

- A, AAAA, CNAME, MX, NS, TXT, SOA, SRV, PTR: mỗi bản ghi trả câu hỏi khác về hạ tầng.
- Tập hosts ánh xạ thủ công tên sang IP, hữu ích kiểm thử cục bộ, xác minh vHost.
- DNS lập bản đồ mail, tên miền con, tích hợp bên thứ ba, thay đổi cấu trúc mạng.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 5/19 — Điều tra DNS

Giới thiệu công cụ truy vấn, nhất là dig. Hiểu cách hỏi loại bản ghi cụ thể, diễn giải đúng.

- Công cụ: dig, nslookup, host, dnsenum, fierce, dnsrecon, theHarvester, dịch vụ tra trực tuyến.
- Truy vấn: A, AAAA, MX, NS, TXT, CNAME, SOA, tra ngược, +trace theo chuỗi phân giải.
- Đọc header, answer section, TTL, máy trả, cờ dig quan trọng ngang chạy lệnh.
- Không đánh giá quá cao ANY; nhiều máy hiện đại hạn chế.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 6/19 — Tên miền con

Mở rộng đáng kể bề mặt tấn công. Có thể chứa phát triển, staging, quản trị, ứng dụng cũ, nội dung nhạy cảm không thấy ở miền chính.

- Khái niệm DNS, thường công bố qua A, AAAA, CNAME.
- Dev/stage hay kiểm soát yếu, lộ chức năng chưa gia cố.
- Khám phá tốt kết hợp chủ động, nguồn thụ động như CT log, tìm kiếm.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 7/19 — Dò vết cặn tên miền con

Thủ hệ thống tên có khả năng trên miền mục tiêu. Chất lượng danh sách từ ảnh hưởng trực tiếp kết quả.

- Luồng: chọn danh sách, sinh ứng viên, hỏi DNS, xác minh phản hồi.
- Danh sách chung, theo bối cảnh, hoặc tùy chỉnh từ thông tin đã thu.
- Công cụ: dnsenum, fierce, dnsrecon, amass, assetfinder, puredns.
- Tìm ra chưa kết thúc; cần xác minh, ưu tiên.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 8/19 — Chuyển vùng DNS

Chức năng hợp lệ sao chép zone giữa máy DNS, thường AXFR. Cấu hình sai có thể lộ toàn zone cho client không được phép.

- AXFR thành công lộ tên miền con, IP, NS, MX, CNAME, A/AAAA, bản ghi khác.
- Rủi ro ở kiểm soát truy cập: chỉ cho máy thứ cấp được phép.
- Thất bại vẫn có thể lộ hành vi, cấu hình máy có thẩm quyền.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 9/19 — Máy chủ ảo (Virtual Hosts)

Nhiều website chung IP, cổng, phân biệt chủ yếu header Host. Không phải host hữu ích nào cũng ở DNS công khai.

- Tên miền con là DNS; vHost là cấu hình máy chủ web.
- Name-based virtual hosting phổ biến nhất, dùng Host chọn nội dung.
- Có thể không có DNS công khai; fuzzing Host, tệp hosts quan trọng.
- Công cụ: Gobuster, Feroxbuster, ffuf.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 10/19 — Nhật ký minh bạch chứng chỉ

CT log là bản ghi chứng chỉ đã cấp, công khai, kiểm toán được. Một trong nguồn thụ động tốt nhất tìm tên miền con thật dùng trong chứng chỉ.

- SAN thường lộ nhiều tên gắn miền, tên miền con.
- Ngoài hiện tại, tìm tên lịch sử, chứng chỉ cũ/hết hạn.
- crt.sh, Censys; API crt.sh để tự động bằng curl, jq.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 11/19 — Nhận diện công nghệ (Fingerprinting)

Tìm stack thật: máy chủ web, CMS, framework, thành phần bảo mật, cấu hình sai. Định hướng bước trình sát sau.

- Thu banner, HTTP header, hành vi ứng dụng, nội dung trang.
- Server, X-Powered-By, tuyến cụ thể, wp-json, chú thích, tệp công khai nhận diện công nghệ.
- Wappalyzer, BuiltWith, WhatWeb, Nmap, Netcraft, wafw00f, Nikto, curl.
- Tìm WAF sớm quan trọng vì có thể đổi/lọc hành vi quan sát.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 12/19 — Thu thập theo liên kết (Crawling)

[LAB_CREDENTIAL_REDACTED] tự động đi liên kết thật. Khác fuzzing, tìm trang/tài nguyên từ tham chiếu ứng dụng sẵn có.

- Từ URL khởi đầu, trích liên kết, lặp tiếp.
- Theo chiều rộng lập bản đồ rộng; theo chiều sâu nhanh đào một nhánh.
- Ngoài liên kết còn chú thích, metadata, tệp nháy cảm, ảnh, media, cấu trúc điều hướng.
- Giá trị ở liên hệ phát hiện, bối cảnh xuất hiện.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 13/19 — robots.txt

Hướng dẫn crawler hợp lệ nên/không nên thu gì. Không phải bảo mật, nhưng hay chỉ thư mục/vùng không muốn lập chỉ mục.

- Khởi theo user-agent; Disallow, Allow, Crawl-delay, Sitemap.
- Disallow có giá trị trình sát nhất, có thể chỉ admin, private, backup, old...
- Có thể lộ bẫy [LAB_CREDENTIAL_REDACTED], sitemap mở rộng liệt kê.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 14/19 — URI chuẩn được biết trước (Well-Known URIs)

/.well-known/, chuẩn RFC 8615, tập trung metadata/cấu hình giao thức, dịch vụ. Nguồn endpoint, dữ liệu có cấu trúc dự đoán được.

- Ví dụ: security.txt, change-[LAB_PASSWORD_REDACTED], assetlinks.json, mta-sts.txt, openid-configuration.
- openid-configuration lộ issuer, authorization endpoint, token endpoint, userinfo endpoint, jwks_uri, scopes, response types.
- Giá trị ở tính dự đoán: dùng giao thức cụ thể thường có đường chuẩn trong /.well-known/.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 15/19 — Công cụ thu thập web (Creepy Crawlies)

Công cụ crawling, nhấn Scrapy với spider tùy chỉnh cho trình sát. Không chỉ thăm trang mà thu theo nhóm hữu ích.

- Burp Suite Spider, OWASP ZAP, Scrapy, Apache Nutch.
- ReconSpider xuất JSON: email, links, external_files, js_files, form_fields, ảnh, media, chú thích.
- Lợi ích lớn là thu có cấu trúc, sẵn sàng xem, liên hệ sau.
- Đạo đức vận hành: ủy quyền, kiểm soát lượng, bảo vệ tài nguyên mục tiêu.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 16/19 — Khám phá bằng công cụ tìm kiếm

Nguồn trình sát thụ động mạnh. Kết hợp toán tử tìm trang, tệp, mẫu cụ thể công khai đã lập chỉ mục.

- site:, inurl:, filetype:, intitle:, intext:, cache:, allinurl:, allintitle:, dấu ngoặc kép, OR, AND, NOT, dấu trừ.
- Google Dorking dùng chiến lược tìm đăng nhập, tài liệu công khai, cấu hình lộ, sao lưu.
- Không lập chỉ mục mọi thứ; bổ sung chứ không thay liệt kê khác.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 17/19 — Kho lưu trữ web

Đặc biệt Wayback Machine, cho lịch sử mục tiêu; tìm trang, thư mục, tên miền con, nội dung từng tồn tại nay không hiện.

- Luồng khái niệm: thu, lưu trữ, truy cập snapshot theo ngày.
- So cũ/hiện tại tìm legacy, endpoint bị xóa, mẫu thay đổi.
- Rất thụ động, hữu ích OSINT, tạo giả thuyết mới.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Phần 18/19 — Tự động hóa trình sát

Tăng tốc, chuẩn hóa, mở rộng. Thay lập thủ công, công cụ mô-đun gom header, WHOIS, SSL, DNS, tên miền con, crawling, thư mục, lịch sử thành một luồng.

- Hiệu quả, mở rộng, nhất quán, bao phủ rộng, tích hợp nguồn/công cụ khác.
- FinalRecon, Recon-ng, theHarvester, SpiderFoot, OSINT Framework.
- FinalRecon là trọng tâm thực tế: nhiều mô-đun hữu ích, giao diện đơn giản, đầu ra tái sử dụng.

Không lưu thực hành riêng; chỉ lý thuyết, giữ luồng trình bày.

Phần 19/19 — Đánh giá kỹ năng

Không lý thuyết mới; tích hợp thực hành. Chứng minh nắm luồng trình sát, không chỉ lập lệnh riêng.

- WHOIS, robots.txt, dò tên miền con, crawling, phân tích kết quả.
- Tên miền con/máy mới phải thêm hosts để truy cập, xác minh cục bộ.
- Đo quy trình, liên hệ, quyết định, không chỉ đáp án.

[Bài thực hành và nhật ký lab đã được lược bỏ khỏi bản công khai; xem module chính thức để tự thực hành.]

Kết thúc

11) Trạng thái trong cuộc trò chuyện gốc: hoàn thành. Yêu cầu cuối người dùng: đã xong mô-đun, xuất bản ghi chép cuối mô-đun này.

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn ([LAB_URL_REDACTED]) Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem [ATtribution.md](Attribution.md) và License.